

Security+ 4.1 · Secure Baselines

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 4.1 — Secure Baselines (4:11)** · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: A secure baseline is a standardized configuration applied to all systems, including a hardened gold image (e.g., CIS benchmarks), automatic patching, MFA, and EDR. Deployment should be automated using tools like GPO, Intune, Ansible, or SCCM—never manual.

High-Yield Core Concepts Tested on Exam

- Baseline: minimum security configuration for all systems
- Gold image: pre-hardened system template
- Automated deployment: GPO, Intune, Ansible, SCCM
- Manual configuration is error-prone and inconsistent
- Baselines include patch management, MFA, EDR
- CIS benchmarks provide hardening guidelines

Exam Tips & Classic Scenarios

- 'baseline configuration applied to all workstations' = secure baseline
- Automate baseline deployment to ensure consistency
- Baselines reduce attack surface and configuration drift

Typical Exam Scenario: All company workstations use the same hardened image with automatic patching and EDR. This is an example of a secure baseline.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 4.1 — Secure Baselines)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. The NIST CSF framework organizes security into 5 functions. What are they?

- A)** Install, Update, Test, Audit, Archive
- B)** Identify, Protect, Detect, Respond, Recover
- C)** Plan, Do, Check, Act, Review
- D)** Prevent, Punish, Predict, Prove, Publish

2. Corporate scenario (Secure Baselines): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.1), an analyst evaluates the following technical requirement: 'Baseline: the minimum configuration that every machine follows'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Baseline: the minimum configuration that every machine follows...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

3. Corporate scenario (Secure Baselines): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.1), an analyst evaluates the following technical requirement: 'Automated deployment (GPO/Intune): never manual'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to speed up system throughput
- B)** Implement the corresponding solution: Automated deployment (GPO/Intune): never manual...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

4. Corporate scenario (Secure Baselines): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.1), an analyst evaluates the following technical requirement: '"baseline configuration applied to all workstations'=secure baseline'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: 'baseline configuration applied to all workstations'=secure baseline...
- D)** Allow shared access among administrators with generic credentials

5. Corporate scenario (Secure Baselines): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.1), an analyst evaluates the following technical requirement: 'all company machines have the same hardened image'=secure baseline. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: 'all company machines have the same hardened image'=secure baseline...

6. Corporate scenario (Secure Baselines): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.1), an analyst evaluates the following technical requirement: 'Baseline: the minimum config that every machine follows.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Baseline: the minimum config that every machine follows...
- D)** Allow shared access among administrators with generic credentials

7. Corporate scenario (Secure Baselines): During a security review and compliance audit aligned with the CompTIA Security+ (SY0-701, Section 4.1) exam, an analyst evaluates the following technical requirement: 'Automated deployment (GPO/Intune): never manual'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: Automated deployment (GPO/Intune): never manual...

8. Corporate scenario (Secure Baselines): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.1), an analyst evaluates the following technical requirement: "baseline configuration applied to all workstations'=secure baseline'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'baseline configuration applied to all workstations'=secure baseline...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

9. Corporate scenario (Secure Baselines): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.1), an analyst evaluates the following technical requirement: "all company machines have the same hardened image'=secure baseline.'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: 'all company machines have the same hardened image'=secure baseline....
- D)** Allow shared access among administrators with generic credentials

10. Corporate scenario (Secure Baselines): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.1), an analyst evaluates the following technical requirement: 'Baseline: the minimum configuration that every machine follows.' What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Baseline: the minimum configuration that every machine follows...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) B — Identify, Protect, Detect, Respond, Recover.

✓ **Why it's correct:** The NIST Cybersecurity Framework (CSF) 2.0 organizes cybersecurity activities into five core functions: Identify, Protect, Detect, Respond, and Recover. These functions represent the complete lifecycle of cyber risk management. 'Identify' involves understanding the organizational context, assets, risks, and vulnerabilities. 'Protect' covers implementing safeguards to ensure delivery of critical services. 'Detect' defines activities to identify the occurrence of cybersecurity events. 'Respond' comprises actions taken after an incident is detected. 'Recover' focuses on restoring capabilities or services that were impaired. This framework is widely adopted and required in the Security Architecture and Design domain of the CompTIA Security+ (SY0-701) certification, specifically in objective 2.1, which deals with frameworks and guidelines.

✗ **Why the others are wrong:**

- *Install, Update, Test, Audit, Archive:* These terms describe generic steps of an IT operational process, such as a software lifecycle or patch management, but they do not constitute the NIST CSF functions. 'Install' and 'Update' refer to system deployment and maintenance; 'Test' is a verification activity; 'Audit' is a compliance assessment; and 'Archive' is a data retention practice. None of these actions correspond to the high-level strategic functions defined by the NIST CSF, which are risk-oriented rather than tactical tasks.
- *Plan, Do, Check, Act, Review:* This is a variation of the PDCA cycle (Plan-Do-Check-Act), used in quality management and continuous improvement systems, such as ISO 9001. Although the NIST CSF can be integrated into continuous improvement processes, its five functions are not 'Plan, Do, Check, Act, Review'. PDCA is a generic management model, while CSF functions are specific to cybersecurity and have their own scope and definitions. The inclusion of 'Review' as a fifth step is a distortion, as the classic PDCA has four steps.
- *Prevent, Punish, Predict, Prove, Publish:* These terms are not part of any recognized cybersecurity framework. 'Prevent' is a goal, but not a CSF function; 'Punish' is a disciplinary or legal action, not a security function; 'Predict' is an aspirational goal, not an operational function; 'Prove' and 'Publish' are audit and communication actions, respectively, but they do not compose the NIST CSF structure. This alternative mixes concepts of justice, prediction, and disclosure, with no relation to the official functions of the framework.

2) A — Implement the corresponding solution: Baseline: the minimum configuration that every machine follows....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.1 (Secure Baselines): Baseline: the minimum configuration that every machine follows. A secure baseline is a standardized set of security settings and configurations applied to systems to ensure a consistent and secure starting point, reducing vulnerabilities and simplifying compliance auditing.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual

accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

3) B — Implement the corresponding solution: Automated deployment (GPO/Intune): never manual....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.1 (Secure Baselines): Automated deployment (GPO/Intune): never manual.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to speed up system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

4) C — Implement the corresponding solution: 'baseline configuration applied to all workstations'=secure baseline....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.1 (Secure Baselines): 'baseline configuration applied to all workstations'=secure baseline.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

5) D — Implement the corresponding solution: 'all company machines have the same hardened image'=secure baseline....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.1 (Secure Baselines): 'all company machines have the same hardened image'=secure baseline.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

6) C — Implement the corresponding solution: Baseline: the minimum config that every machine follows....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.1 (Secure Baselines): Baseline: the minimum config that every machine follows.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

7) D — Implement the corresponding solution: Automated deployment (GPO/Intune): never manual....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.1 (Secure Baselines): Automated deployment (GPO/Intune): never manual. Automated deployment ensures consistency, reduces human error, and enforces secure baselines across the organization.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detect incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

8) A — Implement the corresponding solution: 'baseline configuration applied to all workstations'=secure baseline....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.1 (Secure Baselines): 'baseline configuration applied to all workstations'=secure baseline.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

9) C — Implement the corresponding solution: 'all company machines have the same hardened image'=secure baseline.....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.1 (Secure Baselines): 'all company machines have the same hardened image'=secure baseline.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

10) A — Implement the corresponding solution: Baseline: the minimum configuration that every machine follows....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.1 (Secure Baselines): Baseline: the minimum configuration that every machine follows. A secure baseline establishes a standardized, hardened configuration that all systems must adhere to, reducing the attack surface and ensuring consistency across the environment.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.